

★ Gold Book – Application web sécurisée (Projet de fin de 1ère année BTS SIO)

Projet encadré – Focus sécurité – Option SLAM

Contexte du projet

Gold Book est un projet réalisé en **fin de première année de BTS SIO**.

L'objectif était de créer un **Livre d'Or en ligne** permettant aux visiteurs de laisser un message (commentaire, signature, coordonnées de base).

Mais surtout, ce projet avait une **finalité pédagogique très précise : apprendre à sécuriser une application web**.

Pendant ce projet, le professeur jouait volontairement le rôle d'“attaquant” : le but était de rendre le site **impossible à exploiter**, malgré des tentatives :

- d'injection SQL
- de spam automatique
- d'attaques XSS
- de robots / bots de soumission
- de contournement de formulaires
- d'envoi massif de requêtes
- d'inputs malveillants (scripts, HTML, caractères spéciaux...)

Ce projet nous a permis de comprendre concrètement **les risques de sécurité dans une application PHP** et surtout comment s'en protéger correctement.

Objectifs pédagogiques

- Créer un formulaire complet de signature (Nom, Prénom, Email, Sexe, Commentaire).
 - Stocker les données en base tout en évitant les injections.
 - Sécuriser chaque champ du formulaire via :
 - filtres PHP,
 - regex,
 - échappements HTML,
 - vérification côté serveur.
 - Éviter l'automatisation (bots) via :
 - délais anti-spam,
 - honeypot,
 - sécurité invisible.
 - Mettre en place une page de **consultation** propre et protégée contre les XSS.
-

Fonctionnalités principales

✓ Signature (côté utilisateur)

- Formulaire propre, clair et responsive.
- Validation complète côté serveur.
- Filtrage strict pour empêcher :
 - scripts,
 - balises HTML,
 - caractères interdits,
 - mails invalides.

✓ Consultation (côté public)

- Affichage des signatures validées.
- Contenu entièrement échappé → **impossibilité d'exécuter du script**.

✓ Sécurité intégrée

- Protection anti-injection via requêtes préparées (PDO).
 - Protection contre les attaques XSS via `htmlspecialchars()`.
 - Honeypot invisible pour repérer les bots.
 - Système anti-spam empêchant l'envoi massif en boucle.
 - Vérification de la longueur des champs + filtrage avancé.
-



Ce que j'ai appris

Ce projet m'a permis de comprendre que la sécurité :

- **n'est pas un bonus**, mais une partie essentielle de tout projet web,
- se travaille **dès la conception**, pas seulement après,
- nécessite de penser comme un attaquant,
- demande une rigueur constante dans tous les champs de formulaire.

Il m'a aussi aidé à solidifier mes bases en :

- PHP,
 - SQL sécurisé (requêtes préparées),
 - contrôle des entrées utilisateur,
 - bonnes pratiques backend.
-

Signer

Consulter

 Livre d'Or - Signature

Nom :

Prénom :

Email :

Numéro :

Sexe :

Masculin

Commentaire :

Signature :

Signer